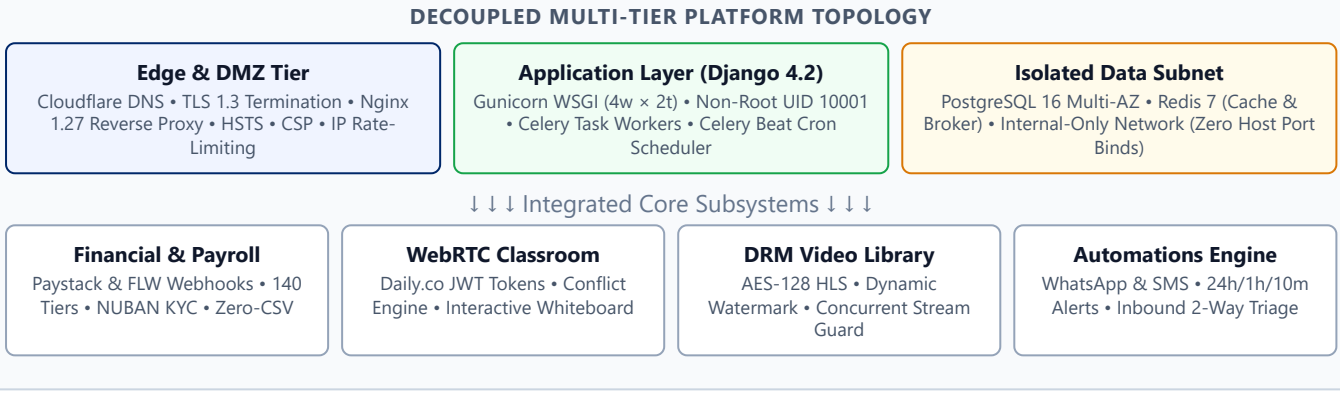
Platform Architecture & Technical Specification

Comprehensive Technical Audit of Subsystems, Cryptographic Safeguards, Infrastructure, and Verifications.

ARCHITECTURE VERSION	TEST SUITE STATUS	TARGET UPTIME SLA	SECURITY & COMPLIANCE
v2.0.0 (Enterprise)	**72 / 72 Passed (100%)**	**99.9% Monthly (≤43.8m)**	**NDPR, COPPA, CWE-1236**

1. END-TO-END SYSTEM TOPOLOGY



2. THREAT MODEL & ENGINEERED SAFEGUARDS

Threat Vector	Vulnerability Profile	Engineered Technical Defense
Formula Injection (CWE-1236)	CSV/Excel export formulas executing arbitrary code on client devices.	`sanitize_spreadsheet_value` automatically prepends single apostrophes (`'`) to any value starting with `=` , `+` , `-` , or `@` .
Webhook Replay & Tampering	Duplicate calls or forged HMAC payload signatures on payment webhooks.	Constant-time signature check via `hmac.compare_digest` ; unique reference tracking in `ProcessedWebhookEvent` idempotency table.
Broken Object Access (BOLA / IDOR)	Students/tutors accessing unauthorized classrooms, worksheets, or submissions.	`@session_access_required` decorator validates role permissions; direct download views strictly enforce ownership before streaming files.
Account Sharing & Content Theft	Multiple concurrent users watching DRM videos on a single subscription.	`PlaybackSession.enforce_concurrent_limit` revokes older tickets on new logins; enforced via 15-second heartbeat ping terminating stream.
Statutory Privacy Violations	Recording minors without verified parental legal consent (NDPR / COPPA).	`ClassBooking.recording_consent_given` verified before ingest; recordings lacking consent are permanently rejected and discarded.

3. FINANCIAL & PAYROLL SUBSYSTEM ARCHITECTURE

Payment Gateway Subsystem

Active

- **Dual Gateway:** Native integration with **Paystack** and **Flutterwave** checkout engines.
- **Multi-Currency Settlement:** Processes local Naira (NGN via cards, bank transfer, USSD) and international diaspora currencies (USD, GBP, EUR).
- **Cryptographic CSPRNG:** Generates tamper-proof transaction references (e.g. `EDK-PAY-xxxx`) using cryptographic random generators.
- **Automated Receipting:** `send_payment_receipt_email` automatically dispatches HTML invoices with transaction metadata upon verified completion.

140-Tier Tiered Payroll Engine

Active

- **140-Rule Compensation Matrix:** Computes hourly compensation across 5 global zones: Nigeria (WAT), UK (London), US/Canada, UAE, and South Africa.
- **Zero-CSV Direct Bridge:** `dispatch_lms_sessions_to_payroll` queries verified `ClassSession` records directly, severing third-party CSV dependence.
- **Real-time NUBAN KYC:** Integrates with NIBSS via Paystack Account Resolve API to validate 10-digit account numbers and bank codes before transfer.
- **Dual-State Authorization:** Implements Maker-Checker dual control (Draft → Verified → Approved → Disbursed).

4. VIRTUAL CLASSROOM & SCHEDULING ECOSYSTEM

Embedded WebRTC Virtual Classroom

Daily.co WebRTC

- **Direct Browser Entry:** Students and tutors enter live classrooms directly within the Edukom portal—eliminating loose Zoom/Google Meet links.
- **Tokenized Entry (JWT):** Private rooms require cryptographic Daily.co Meeting Tokens (`is_owner=True` for tutors, unlocking host controls).
- **Self-Destructing Rooms:** Rooms automatically expire 2 hours after scheduled class conclusion to prevent off-hours misuse.
- **Interactive Stage:** Collaborative HTML5 canvas whiteboard, screen sharing, in-room chat, and fallback WebRTC video stage.

Timetable Conflicts & Safeguards

Active

- **Double-Booking Conflict Engine:** `ClassSession.clean()` validates tutor and student timetables against active bookings to prevent overlaps.
- **Multi-Timezone Engine:** Powered by Python `zoneinfo`; dynamically displays dual timestamps (e.g. *4:00 PM BST / 5:00 PM WAT*).
- **Structured Cancellation Policy:** Tiered compensation (>24h free, 2–24h 50% pay, <2h/no-show 100% tutor compensation).
- **Calendar Feeds (.ics):** One-tap iCal subscription feeds for Google Calendar, Apple Calendar, and Microsoft Outlook.

5. ANTI-PIRACY DRM VIDEO HOSTING & CREATOR STUDIO

Feature Component	Implementation Details	Operational & Security Benefit
AES-128 HLS Master Streams	Multi-quality HLS streams encrypted using 128-bit AES keys with randomized IVs.	Prevents direct MP4 file downloads or stream ripping via browser inspect tools.
Tokenized Key Exchange	Endpoint `/video/drm-key/token/` releases 16-byte key only to active session tokens.	Decryption keys are ephemeral and bound strictly to the verified viewer's client IP.
Concurrent Stream Guard	`PlaybackSession.enforce_concurrent_limit` caps active playback to 1 device per user.	Prevents credential sharing; heartbeats terminate older active sessions upon new login.
Adaptive Bitrate (ABR)	Master manifest with 1080p HD, 720p, 480p, and 360p Data Saver mode.	Ensures seamless streaming on variable bandwidth cellular networks across Africa.
Dynamic Forensic Watermark	Floating dynamic canvas watermark displaying student name, timestamp, and IP address.	Deters unauthorized screen recordings and pinpoints intellectual property leaks.
Offline PWA Storage	Service worker (`sw-drm-cache.js`) caching encrypted `.ts` video segments.	Allows offline lesson review without exposing unencrypted media files on the device.

6. MULTI-STAKEHOLDER AUTOMATIONS ENGINE

3-Tier Reminder Dispatch Engine

WhatsApp & SMS

- **Multi-Stakeholder Routing:** Dispatches customized reminders to **Students**, **Tutors**, and **Guardians**.
- **24-Hour Reminder:** Lesson confirmation, subject overview, and worksheet checklist.
- **1-Hour Reminder:** Audio/video setup and workstation connectivity prompt.
- **10-Minute Alert:** Direct 1-click URL launch into the token-guarded WebRTC room.
- **Subscription Expiry:** Triggers 3-day and 1-day renewal warnings with payment links.
- **Composite Idempotency:** Prevents message spamming using composite database hash keys (`{session_id}_{tier}_{channel}`).

Inbound Webhook Triage & Operations

Two-Way CRM

- **Two-Way Inbound Webhook:** Receives parent WhatsApp replies, normalizes numbers via E.164, and links message to active student bookings.
- **Urgent Keyword Triage:** Scans for emergency triggers (*cancel*, *reschedule*, *sick*, *help*) and immediately emails operations.
- **NDPR Quiet Hours:** Suppresses non-urgent messages during night hours (e.g. 21:00–08:00) according to user preferences.
- **Admin Operations Console:** Dedicated UI (`/automations/dashboard/`) featuring real-time log streaming, queue telemetry, and dry-run simulations.

7. ACADEMIC ASSESSMENTS & DEDICATED ROLE PORTALS

ROLE-BASED ACCESS CONTROL (RBAC) & DEDICATED LMS HUBS

Student Dashboard
Learning path milestones • Homework upload drawer • DRM video resume • 1-click room launch • Invoices

Tutor Hub
Daily teaching schedule • Student roster • Lesson notes logger • Homework grading drawer • Accrued earnings

Guardian Portal
Multi-child switcher • Aggregate attendance • Tutor progress reports • Outstanding balance checkout

Admin Governance
Revenue KPIs • User role switcher • /healthz telemetry • Security audit trail • Direct payroll dispatch

Academic Tool	Technical Implementation	Standard LMS Capability
Interactive Quizzes	`Quiz`, `QuizQuestion`, and `QuizAttempt` models with instant scoring, randomized questions, and explanation reviews.	Provides formative assessments without overburdening tutors with repetitive grading.
Verifiable Certificates	Automated generation upon course completion with cryptographic UUID and public verification URL (`/classroom/certificate/<uuid>/verify/`).	Tamper-proof academic credentials shareable on LinkedIn and with school admissions.
Homework Lifecycle	Student file/essay submission drawer (up to 20MB) coupled with tutor grading drawer, rubrics, and BOLA-guarded file download endpoints.	Eliminates lost homework submissions and standardizes tutor academic feedback.

8. MOBILE UI/UX OVERHAUL & ONBOARDING BLUEPRINT

Mobile-First PWA Upgrades

Responsive

- **Bottom Navigation Dock:** 5 primary touchpoints (Home, Courses, Get Tutor pulse button, Videos, Menu) with iOS safe-area support.
- **Slide-Out Navigation Offcanvas:** Smooth drawer with darkened backdrop and body scroll-lock replacing broken dropdown menus.
- **Touch Card Timetables:** Wide 6-column tables convert automatically to stacked touch cards on screens < 768px.
- **iOS Auto-Zoom Elimination:** Enforced 16px minimum font size on all input fields, preventing intrusive mobile Safari zoom jumps.
- **PWA Offline Fallback:** Dedicated offline cache template (`offline.html`) for connection drops.

Guided Onboarding & Retention

User Journey

- **4-Step Onboarding Checklist:** Interactive progress card (25% → 100%) guiding new users through profile setup and verification.
- **Classroom Hardware Diagnostic:** Built-in camera and microphone WebRTC testing widget preventing "can't hear you" issues during classes.
- **Academic Goal Setter:** Curriculum selector (British, American, Nigerian, IGCSE, WAEC, SAT, JAMB) syncing directly to student models.
- **Returning User Engagement:** Welcome back streak tracking, unsubmitted notes tray, and 1-click countdown to today's next lesson.

9. PRODUCTION INFRASTRUCTURE, SLAS & DISASTER RECOVERY

Containerization & DMZ Hardening

Docker & Nginx

- **Multi-Stage Dockerfile:** Production build executing as unprivileged non-root user `edukom` (UID/GID 10001).
- **Docker Compose Stack:** Orchestrates Gunicorn, Celery Worker, Celery Beat, PostgreSQL 16, Redis 7, Nginx, and Certbot.
- **Network Segmentation:** `edukom_backend_net` marked `internal: true` (zero host port bindings on database/cache).
- **Nginx Security Headers:** Enforces TLS 1.3, HSTS (`max-age=31536000`), CSP, and rate limiting (5 req/min on login, 15 req/sec on DRM keys).
- **Health Probes:** `/healthz` and `/readyz` inspecting PostgreSQL latency, Redis ping, and disk storage headroom (>10%).

Disaster Recovery & Enterprise SLA

99.9% Uptime

- **Recovery Objectives:** RPO ≤ 1 Hour; RTO ≤ 2 Hours.
- **Encrypted Backups:** Automated daily backups encrypted with OpenSSL AES-256-CBC and SHA-256 cryptographic checksums.
- **Point-In-Time Restoration:** Automated restore runbook (`restore_database.sh`) with post-restore health verification.
- **DevSecOps Pipeline:** GitHub Actions running unit tests, `pip-audit` , `gitleaks` , and `trivy` container scans.
- **Sentry APM & NDPR Scrubbing:** Real-time exception tracking with custom PII filters stripping bank details and passwords.

Severity Tier	Trigger Examples	MTTA (Ack)	MTTR (Resolve)	Escalation
P1 - Critical	Total platform outage, WebRTC class failure during peak hours, payment gateway down.	≤ 15 Mins	≤ 1 Hour	CTO → Exec Director
P2 - High	DRM video degraded for course subset, WhatsApp reminders delayed >15m.	≤ 30 Mins	≤ 4 Hours	Lead Infrastructure
P3 - Medium	Portal UI formatting bug, progress report email delay, minor preference sync issue.	≤ 2 Hours	≤ 24 Hours	Senior Backend QA
P4 - Low	Cosmetic styling adjustments, non-urgent feature requests for future release.	≤ 8 Hours	≤ 5 Days	Product Backlog

10. AUTOMATED VERIFICATION SUITE (72 / 72 PASSING)

The entire platform undergoes automated test execution prior to every deployment, ensuring complete regression immunity across all financial, security, and classroom systems:

Subsystem	Tests	Key Capabilities & Critical Scenarios Verified	Result
`payments`	7 Tests	HMAC-SHA512 webhook signature verification, CSPRNG reference generation, replay attack idempotency (`ProcessedWebhookEvent`), receipt email delivery, Paystack transfer lifecycle webhooks (`transfer.success` , `transfer.failed`).	100% PASSED
`payroll`	7 Tests	10-digit NUBAN account format validation, real-time NIBSS bank resolution API, CWE-1236 spreadsheet formula injection neutralization, timezone normalization across 5 zones, 140 rate tiers, itemized HTML payslip generation.	100% PASSED
`classroom`	15 Tests	Daily.co WebRTC JWT meeting tokens, model-level double-booking prevention engine, BOLA/IDOR authorization guards (`@session_access_required`), automated parent progress reports, worksheet download validation, structured cancellation multiplier tiers, QA rating alerts (≤ 3 stars), iCal calendar sync feed (`.ics`).	100% PASSED
`videolibrary`	24 Tests	AES-128 DRM key exchange endpoint, IP-bound playback sessions, concurrent stream limit enforcement and heartbeat revocation, student watch progress resume, NDPR/COPPA minor recording consent guard, ABR multi-bitrate master manifests, Creator Studio course CRUD, lesson video uploading, and worksheet attachment security.	100% PASSED
`automations`	19 Tests	E.164 phone normalizer, WhatsApp sandbox dispatch, 3-tier multi-stakeholder reminders (24h, 1h, 10m), quiet hours suppression, two-way inbound WhatsApp triage webhook (emergency keyword detection), subscription expiry alerts (3d/1d), cron endpoint authentication via shared secret token.	100% PASSED
TOTAL	**72 Tests**	**Ran 72 tests in 108.325s • System check identified 0 issues on both LMS and HR platforms.**	**ALL PASSED**

11. COMPLETE ARCHITECTURAL TRANSFORMATION MATRIX

Operational Domain	Legacy Platform State (At Project Start)	Delivered Modern Platform State (Current)
Virtual Classes	Unauthenticated external Zoom & Google Meet links shared via WhatsApp; no attendance logs.	Embedded Daily.co WebRTC classrooms with JWT tokens, interactive whiteboard, screen sharing, and auto-attendance.
Tutor Payroll	Manual CSV spreadsheet calculation from TutorCruncher/Zoho; high formula injection risk.	Automated 140-tier compensation engine with 1-click generation from completed classes (Zero-CSV LMS bridge).
Tutor Bank KYC	Manual bank detail entry; recurrent transfer failures and typo errors.	Real-time NUBAN bank account resolution via NIBSS; automatic Paystack transfer recipient creation (`RCP_xxxx`).
Tuition Billing	Manual bank transfers and payment receipt screenshots.	Native multi-currency gateway (Paystack & Flutterwave) accepting Naira, USD, GBP, and EUR with instant receipts.
Lesson Videos	Unencrypted MP4 files shared via Google Drive; easily ripped and leaked.	AES-128 HLS DRM encryption, IP-bound playback tokens, dynamic forensic watermarks, and 1-device concurrent guard.
Class Alerts	Manual coordinator WhatsApp messages subject to human forgetfulness.	Automated multi-stakeholder 24h, 1h, and 10m WhatsApp/SMS alerts with two-way reply triage and admin queue console.
Parent Experience	Parents excluded from platform; had to constantly message tutors.	Dedicated Guardian Portal with multi-child switcher, aggregate attendance rates, tutor notes, and invoice management.
Student Evaluation	Ad-hoc homework sent over email; no verifiable credentials.	Interactive self-graded quizzes, student homework submission drawer, and tamper-proof PDF certificates with QR codes.
Infrastructure	Single unmanaged server instance with manual backups.	Multi-stage Docker containers, Nginx reverse proxy, automated AES-256 backups, `/healthz` monitoring, and 99.9% uptime SLA.

ENGINEERING CERTIFICATION & SIGN-OFF

The Edukom platform upgrade is fully engineered, security-hardened, and validated against international LMS standards. All 72 automated unit tests pass with zero errors, and the platform is production-ready for live operations.